Smart Attendance · Relatório para o grupo

Rodada de melhorias de segurança e entrega · novembro de 2026
Para: todos os integrantes do projeto (Átila, Matheus, João Vitor e demais)
Site no ar: https://smart-attendance-nine-alpha.vercel.app
Código: https://github.com/AtilaAlvesRodrigues/smart-attendance

> **Em uma frase:** as sete tarefas do quadro foram feitas e o site publicado já tem as melhorias. Faltam poucas coisas, todas listadas na seção 7 com o nome de quem precisa resolver cada uma.

---

1. Resumo rápido

Item	Situação
O que foi pedido	7 tarefas do quadro "A fazer" (cards #42, #48, #49, #50, #52, #53 e #54)
Situação	Todas entregues. A #48 (Vercel) ficou parcial: funciona por um fork e falta um passo do Átila
Site publicado	Já com QR que muda a cada 30 s, proteção CSP, PHP corrigido (8.5.12) e dependências atualizadas
Testes automáticos	238 passando (eram 209)
Pull Requests	9 no total: 6 mergeados, **3 abertos esperando merge** (#61, #62 e #63)
Falhas de segurança	11 registradas: 5 resolvidas, 2 parciais, 4 abertas

O que o grupo precisa fazer antes de apresentar (resumo)

1. **Trocar a senha do Master** no site publicado (hoje é `senha123`, pública no README).
2. **Testar a chamada completa** no site publicado: QR trocando e presença registrada pelo celular.
3. **Mergear os PRs #61, #62 e #63** e sincronizar o fork.

Os detalhes de cada um estão na seção 7.

---

2. O que muda para quem usa o sistema

Professor

- O **QR Code da chamada agora muda sozinho a cada 30 segundos**. Na tela aparece "Troca em N s".
- No modo **Projetar em tela cheia** o QR também troca. Nada precisa ser feito: é só deixar a tela aberta.
- O link para quem está sem câmera (**Copiar link**) entrega o link do momento, que também vale pouco tempo.

Aluno

- Precisa **escanear o QR que está na tela naquele momento**. Foto ou print do QR deixa de funcionar em até 1 minuto.
- Se escanear e ainda não estiver logado, o sistema guarda a presença e conclui depois do login. **Se o login demorar mais de 1 minuto, aparece "Este QR Code expirou"** e basta escanear de novo.

Master (administração)

- Há uma tela nova só para o Master que mostra a **versão do PHP** do servidor: `/dashboard/master/ambiente/php`.
- Nada mais muda no dia a dia.

---

3. O quadro do projeto, card por card

Card	Tarefa	Situação	O que falta
#42	QR Code que muda a cada 30 s	**Feito**, em produção	Testar a chamada no site publicado
#49	Content-Security-Policy	**Feito**, em produção	Nada obrigatório (ver limite na seção 5)
#52	Doc de falhas de segurança	**Feito**	Nada
#50	Licença do repositório	**Feito** (MIT)	Confirmar o nome do titular, se quiserem
#53	Relatório com revisão do projeto	**Feito** (já estava fechada)	Mergear o PR #63
#54	Revisão das actions e novas actions	**Feito**	Átila ligar o *Dependency graph*
#48	Deploy automático da Vercel pelo GitHub	**Parcial**	Ver abaixo

Sobre a #48: o repositório é do Átila e o projeto da Vercel está na conta `jooaoleonardi`. A Vercel não enxergava o repositório do Átila, então criamos um **fork** (`jooaoleonardi/smart-attendance`) e ligamos a Vercel nele. Agora, *push na `main` do fork publica sozinho*. Ainda falta testar com um commit real, e os previews por Pull Request estão desligados (explicado na seção 4.7).

Os cards já têm a **descrição completa** e um **comentário de status**. Nenhum foi fechado ou movido de coluna: isso fica a critério do grupo.

---

4. O que foi feito, explicado

4.1 QR Code que muda a cada 30 segundos (card #42)

Antes: o QR valia 2 horas. Se um aluno tirasse foto e mandasse para um colega fora da sala, o colega registrava presença.

Agora: o link do QR leva um código secreto que muda a cada 30 segundos, calculado a partir da chave do sistema. O servidor aceita o código do momento e o anterior, então uma foto **dura no máximo 60 segundos**.

Limite honesto: um aluno que está na sala ainda pode mandar o link *ao vivo* para um colega ausente, que confirma dentro desse minuto. Isso não é falha técnica, é cumplicidade. A solução seria limitar à rede da instituição (registrado como SEC-05).

4.2 Content-Security-Policy, a CSP (card #49)

O que é: uma regra que o site manda para o navegador dizendo *quais scripts e estilos podem rodar*. Se um atacante conseguisse colocar um código malicioso numa página, o navegador se recusaria a executá-lo.

Antes: a regra existia, mas liberava qualquer código escrito direto na página, o que anulava a proteção.

Agora: só roda código que o próprio servidor marcou com uma **senha de uso único** (o *nonce*, novo a cada acesso). Também foram adicionadas regras contra o site ser aberto dentro de outro site e contra formulários enviados para fora.

Limite honesto: ainda existem cerca de 58 botões com `onclick=` e 539 estilos escritos direto nos elementos, que a regra precisa continuar aceitando. Migrá-los é um trabalho futuro (SEC-08).

4.3 Domínios confiáveis (`trustHosts`)

O problema: o sistema aceitava qualquer endereço no pedido recebido. Alguém mal-intencionado poderia pedir "recuperar senha" de outra pessoa e o e-mail sairia com um link para o site *dele*.

A correção: o sistema só aceita os endereços do próprio projeto. Qualquer outro recebe erro 400. Testamos com o app em modo de produção: `evil.com` foi barrado.

> **Atenção:** se o site ganhar um **domínio próprio** (por exemplo da escola), ele precisa ser cadastrado na variável `TRUSTED_HOSTS` da Vercel. Sem isso, o site responde erro 400 nesse domínio.

4.4 Bibliotecas servidas pelo próprio site

O QR Code e o PDF dependem de três bibliotecas que vinham de um site externo (cdnjs). Se ele fosse invadido, um código malicioso rodaria dentro do nosso sistema. Agora os três arquivos ficam **dentro do projeto**, idênticos aos originais (conferimos o código de verificação de cada um), e um teste automático avisa se alguém alterar. A CSP deixou de aceitar scripts de qualquer site externo.

4.5 Dependências e vulnerabilidades

	Antes	Depois
Pacotes PHP (`composer audit`)	8 avisos de segurança	0
Pacotes de interface (`npm audit`)	6 avisos (2 críticos)	0

Os 8 avisos do PHP também **derrubavam um dos módulos do CI**. Isso foi resolvido.

4.6 As duas falhas críticas do PHP (relatórios do Matheus e do Átila)

Os dois relatórios em PDF falavam de **CVE-2026-109618 e CVE-2026-109619**: falhas gravíssimas no próprio PHP, que podem permitir tomar o servidor. As versões seguras são 8.2.35, 8.3.36, 8.4.27 e 8.5.12.

O que descobrimos depois: - Exigir `8.2.35` no `composer.json` (como o Átila fez) protege quem instala o projeto, mas **não muda o PHP do servidor**, que vem embutido na Vercel. - Investigamos o pacote da Vercel: a versão atual dele embute o **PHP 8.5.12**, e o próprio site responde `PHP/8.5.12`. **Ou seja, a produção está protegida.** - O PHP da máquina de desenvolvimento usada neste trabalho também foi atualizado (8.5.10 → 8.5.12). Quem apresentar rodando local deve fazer o mesmo: `brew upgrade php`.

Cuidado futuro: a versão do PHP depende do momento do deploy. Depois de cada publicação, confira com:

```
curl -sI https://smart-attendance-nine-alpha.vercel.app/login/professor | grep -i x-powered-by
```

4.7 Deploy automático e previews (card #48)

- O fork `jooaoleonardi/smart-attendance` foi criado e a Vercel conectada a ele.
- Para o fork acompanhar o repositório do Átila, rode: `gh repo sync jooaoleonardi/smart-attendance`.
- **Previews desligados** (PR #62): as variáveis do sistema (chave, banco) existem só na produção. Um preview de branch subiria sem elas e daria erro. Para ter previews no futuro, é preciso cadastrar variáveis de "Preview" apontando para um **banco de teste** (nunca o de produção).

> **Cuidado:** a Vercel publica assim que o fork recebe algo na `main`, mesmo que os testes do GitHub falhem.

4.8 Pipeline do GitHub (card #54)

O que	Para que serve
Dependabot	Abre Pull Requests sozinho quando uma dependência tem atualização
Revisão de dependências	Bloqueia um PR que traga pacote com vulnerabilidade (só roda depois que o Átila ligar o *Dependency graph*)
Varredura de segredos	Procura senhas e chaves esquecidas no código
Limite de tempo (15 min)	Impede um teste travado de consumir horas
Relatório em PDF do CI	O módulo 6 já estava quebrado antes (programa `wkhtmltopdf` saiu do Ubuntu); foi trocado e protegido contra texto malicioso

4.9 Licença (card #50)

Foi adicionado o arquivo `LICENSE` com a **licença MIT**, que o Átila já tinha declarado no `composer.json`. Titular: "Equipe Smart Attendance". A MIT permite usar, copiar e modificar o código, mantendo o aviso de autoria.

---

5. Falhas de segurança registradas

O registro completo está em `docs/falhas-de-seguranca.md`.

ID	Falha	Situação
SEC-01	8 avisos de pacotes do PHP (Symfony)	**Resolvida**
SEC-02	**Conta Master da demonstração com senha pública**	**Aberta, urgente**
SEC-03	Aceitava qualquer endereço de site (`Host`)	**Resolvida**
SEC-04	Scripts de site externo sem verificação	**Resolvida**
SEC-05	Link do QR repassado ao vivo para quem está ausente	Parcial
SEC-06	6 avisos nos pacotes de interface (npm)	**Resolvida**
SEC-07	Sem autenticação em dois fatores	Aberta
SEC-08	CSP ainda aceita `onclick=` e `style=`	Parcial
SEC-09	Configuração de exemplo (`.env.example`) com padrões inseguros	Aberta
SEC-10	Tempo de sessão com três valores diferentes	Aberta
SEC-11	**PHP vulnerável (CVE-2026-109618 e 109619)**	**Resolvida em produção**

---

6. Como foi verificado

Testes automáticos: 238 passando, com 1.116 verificações. Entre os novos: o QR rotativo, o nonce em cerca de 30 telas dos quatro perfis, as bibliotecas locais, os domínios confiáveis e a rota do PHP.

No site publicado (sem login): cabeçalho de segurança presente em 13 páginas públicas, nenhum bloco de código sem a "senha" do nonce, bibliotecas servidas pelo próprio site, PHP 8.5.12 e rota do Master protegida (responde 401 sem login).

No navegador, localmente: login do professor, tela da chamada e a troca real do QR em 30 segundos, sem erros no console.

O que NÃO foi testado em produção: o fluxo completo da chamada (QR trocando e presença registrada pelo celular), porque exige login, que o assistente de IA não faz em site publicado.

Erros encontrados e corrigidos durante o trabalho: um teste meu falhava 1 vez em 16 (corrigido); o README dizia 204 testes quando eram 209; a documentação dizia PHP 8.3 no CI quando era 8.4; um comando da Vercel quase escondeu o `.env.example` do Git (desfeito). Todos estão em `docs/relatorios/relatorio-de-modificacoes-2026-11.md`.

---

7. O que falta e quem resolve

#	O que	Quem	Urgência
1	**Trocar a senha do Master em produção**	Quem acessa o banco (Supabase)	**Antes de apresentar**
2	**Testar a chamada no site publicado** (QR, celular, presença)	Quem for apresentar	**Antes de apresentar**
3	Mergear os PRs **#61, #62 e #63** e rodar `gh repo sync jooaoleonardi/smart-attendance`	Quem tem acesso (conta `jooaoleonardi`)	Antes de apresentar
4	Ligar o *Dependency graph* e criar a variável `DEPENDENCY_GRAPH_ATIVO=true`	**Átila** (dono do repositório)	Depois
5	Instalar o app da Vercel no GitHub, se quiserem ligar o repositório oficial	**Átila**	Depois
6	Cadastrar o domínio em `TRUSTED_HOSTS`, se o site ganhar domínio próprio	Quem gerencia a Vercel	Quando houver domínio
7	Fechar as issues concluídas no quadro	Grupo	Depois dos testes

Como trocar a senha do Master (item 1)

Passo 1. No computador, gere o código da senha nova (troque `SENHA_NOVA`, use 12 caracteres ou mais):

```
php -r "echo password_hash('SENHA_NOVA', PASSWORD_BCRYPT, ['cost' => 12]), PHP_EOL;"
```

Passo 2. No **SQL Editor do Supabase**, rode (colando o código gerado no lugar de `<código gerado>`):

```
update laravel.usuario_masters set password = '<código gerado>' where id = 1;
```

Passo 3. Teste o login em **Entrar como Professor**.

> Depois, **remova `senha123` do README e do `CLAUDE.md`**, que são públicos. O histórico do Git continua mostrando a senha antiga, por isso a troca é o que realmente vale.

---

8. Roteiro de teste antes de apresentar (30 minutos antes)

#	Conferir	Como
1	Site carrega	Abrir `/login`: deve aparecer com estilo
2	PHP corrigido	Comando da seção 4.6: deve mostrar `PHP/8.5.12`
3	Senha do Master trocada	Seção 7
4	Os 3 perfis entram	Professor, aluno e Master

#	Conferir	Como
5	QR trocando	Professor abre uma matéria: o QR muda a cada 30 s
6	Presença pelo celular	Aluno logado escaneia: nome aparece na lista em até 3 s
7	Tela cheia	Botão "Projetar em tela cheia" no projetor
8	Relatório em PDF	Gerar e abrir um relatório de presença
9	Plano B	Rodar local: `php artisan serve`

O roteiro de apresentação de ~10 minutos, com as perguntas prováveis, está em `docs/apresentacao.md` (PR #61).

---

9. Regras novas para quem programa

1. **Todo `<script>` ou `<style>` novo numa view precisa de `@nonce`**: `<script @nonce>`. Sem isso o navegador bloqueia e a tela fica quebrada. O teste `CspCoberturaTest` avisa se esquecer.
2. **Bibliotecas externas:** não carregar de CDN. Colocar em `public/js/vendor/` e registrar o hash em `LEIA-ME.md`.
3. **Domínio novo:** entra em `TRUSTED_HOSTS` na Vercel.
4. **Depois de cada deploy**, conferir a versão do PHP (seção 4.6).
5. **Branches de trabalho** (`feat/`, `fix/`, `docs/`, `chore/`, `melhoria/`, `claude/`) não geram preview na Vercel.
6. **Rodar os testes** antes de abrir PR: `php artisan test`.

---

10. Glossário

Termo	O que é
CSP	Regra que o site manda ao navegador dizendo quais códigos podem rodar
Nonce	Código de uso único, novo a cada acesso, que "autoriza" um bloco de script na CSP
XSS	Ataque em que alguém coloca código malicioso numa página
CVE	Número de identificação público de uma vulnerabilidade
RCE	Execução remota de código: o atacante roda comandos no servidor
HMAC	Assinatura calculada com uma chave secreta; só quem tem a chave consegue gerá-la
Host / `trustHosts`	Endereço do site no pedido; `trustHosts` limita quais endereços são aceitos
CDN	Servidor externo que hospeda arquivos usados por vários sites
SRI	Código de verificação que garante que um arquivo externo não foi alterado
CI	Testes que o GitHub roda sozinho a cada alteração
Fork	Cópia de um repositório na conta de outra pessoa

Termo	O que é
Preview	Cópia temporária do site publicada para testar uma alteração
Dependabot	Robô do GitHub que sugere atualização de pacotes
Merge	Juntar as alterações de uma branch na `main`

11. Onde encontrar cada coisa

Documento	Caminho no repositório
Relatório técnico completo	`docs/relatorios/relatorio-de-modificacoes-2026-11.md`
Revisão do projeto	`docs/relatorios/revisao-do-projeto-2026-11.md`
Falhas de segurança	`docs/falhas-de-seguranca.md`
Revisão das Actions	`docs/revisao-github-actions.md`
Deploy e Vercel	`docs/deploy.md`
Roteiro de apresentação	`docs/apresentacao.md` (PR #61)

Pull Request	Assunto	Situação
#55 a #60	QR rotativo, CSP, licença, dependências, CI, rota do PHP	Mergeados
#61	Roteiro de apresentação, senha do Master, SEC-11 resolvida	**Aberto**
#62	Desliga previews de branch na Vercel	**Aberto**
#63	Relatório completo das modificações (md e PDF)	**Aberto**